

Doc Technique

TOTP - CYBERSÉCURITÉ

PERSON Yanis

14 Décembre 2025



Sommaire

1. Introduction
2. Base de données et page index.php
3. Page register.php
4. Page login.php
5. Page totp.php
6. Page accueil.php
7. Conclusion

Introduction

Le **TOTP (Time-based One-Time Password)** est une méthode qui permet de créer des codes à usage unique pour sécuriser l'accès à un compte ou à un service. Ces codes changent automatiquement régulièrement, ce qui rend leur utilisation par une personne non autorisée très difficile.

Le **TOTP** est souvent utilisé dans le cadre de l'authentification à deux facteurs (2FA) pour renforcer la sécurité, en ajoutant un second niveau de protection en plus du mot de passe classique.

Ce document explique de manière technique comment fonctionne le TOTP, comment il est généré et vérifié.

Base de données

J'ai commencé par créer la base de données avec une table unique : users

#	Nom	Type	Interclassement	Attributs	Null	Valeur par défaut	Commentaires	Extra	Action
☐ 1	id	int			Non	Aucun(e)		AUTO_INCREMENT	Modifier Supprimer Plus
☐ 2	username	varchar(50)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 3	email	varchar(100)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 4	password	varchar(255)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 5	created_at	timestamp			Oui	CURRENT_TIMESTAMP		DEFAULT_GENERATED	Modifier Supprimer Plus
☐ 6	temp_password	varchar(6)	utf8mb4_general_ci		Oui	NULL			Modifier Supprimer Plus
☐ 7	temp_updated_at	datetime			Oui	NULL			Modifier Supprimer Plus

Page index.php

Ensuite, j'ai continué avec la création de cette page. Elle permet de récupérer les informations de l'utilisateur (username, email, created_at) depuis la base.

```
// Récupère les informations de l'utilisateur
$stmt = $pdo->prepare("SELECT username, email, created_at FROM users WHERE id = ?");
$stmt->execute([$$_SESSION['user_id']]);
$user = $stmt->fetch(PDO::FETCH_ASSOC);
```

Page register.php

Cette page permet d'inscrire un utilisateur et de créer un compte avec son **nom d'utilisateur, email et son mot de passe**. Elle vérifie aussi que les champs sont valides et que le nom/email n'existe pas déjà dans la base. Puis, elle ajoute l'utilisateur dans la table **users** et redirige vers **login.php**.

```
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $username = trim($_POST['username'] ?? '');
    $email = trim($_POST['email'] ?? '');
    $password = $_POST['password'] ?? '';
    $confirm_password = $_POST['confirm_password'] ?? '';

    // --- Validation des champs ---
    if ($username === '' || $email === '' || $password === '') {
        $error = "Tous les champs sont obligatoires.";
    } elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $error = "Email invalide.";
    } elseif ($password !== $confirm_password) {
        $error = "Les mots de passe ne correspondent pas.";
    } elseif (strlen($password) < 6) {
        $error = "Le mot de passe doit contenir au moins 6 caractères.";
    } else {
        // Vérification si l'utilisateur ou email existe déjà
        $stmt = $pdo->prepare("SELECT id FROM users WHERE username = ? OR email = ?");
        $stmt->execute([$username, $email]);
        if ($stmt->rowCount() > 0) {
            $error = "Nom d'utilisateur ou email déjà utilisé.";
        } else {
            // Insertion de l'utilisateur
            $hashed = password_hash($password, PASSWORD_DEFAULT);
            $stmt = $pdo->prepare("INSERT INTO users (username, email, password) VALUES (?, ?, ?)");
            $stmt->execute([$username, $email, $hashed]);

            // Redirection vers la page de connexion
            header('Location: login.php');
            exit;
        }
    }
}
```

Page login.php

Ensuite, la page login.php permet à un utilisateur de s'identifier avec son nom d'utilisateur ou email et son mot de passe. Elle vérifie les informations dans la table **users**. Si elles sont correctes, elles génèrent un **code temporaire (TOTP)** et le stocke dans les colonnes **temp_password** et **temp_updated_at** de la base.

```
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $login = trim($_POST['login'] ?? '');
    $password = $_POST['password'] ?? '';

    // Vérification des champs
    if ($login === '' || $password === '') {
        $error = "Veuillez remplir tous les champs.";
    } else {
        $stmt = $pdo->prepare("SELECT * FROM users WHERE username = ? OR email = ?");
        $stmt->execute([$login, $login]);
        $user = $stmt->fetch(PDO::FETCH_ASSOC);

        if ($user && password_verify($password, $user['password'])) {

            // --- Génération du code temporaire pour la connexion ---
            $tempCode = str_pad(random_int(0, 999999), 6, '0', STR_PAD_LEFT);

            $stmt = $pdo->prepare(
                "UPDATE users SET temp_password = ?, temp_updated_at = NOW() WHERE id = ?"
            );
            $stmt->execute([$tempCode, $user['id']]);

            // Redirection vers la page OTP avec l'ID utilisateur
            header("Location: totp.php?user={$user['id']}");
            exit;
        } else {
            $error = "Identifiants incorrects.";
        }
    }
}
```

Mise à jour de la base :

- **temp_password** reçoit le code temporaire.
- **temp_updated_at** reçoit la date et l'heure actuelles.

temp_password	temp_updated_at
530061	2025-12-14 16:42:03

.Page totp.php

Ensuite, cette page permet de voir le code **TOTP** affiché sur le site et de le saisir. Elle vérifie que le code saisi correspond à celui stocké dans la base pour l'utilisateur puis, redirige vers la page d'accueil, sinon affiche un message d'erreur.

```
if (!isset($_GET['user'])) {
    die("Aucun utilisateur fourni.");
}

$user_id = intval($_GET['user']);

// --- Récupération du code temporaire en base ---
$stmt = $pdo->prepare("SELECT temp_password FROM users WHERE id = ?");
$stmt->execute([$user_id]);
$user = $stmt->fetch(PDO::FETCH_ASSOC);

if (!$user) {
    die("Utilisateur introuvable.");
}

// --- Gestion du formulaire OTP ---
$error = "";
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $input = trim($_POST['otp']);

    if ($input === $user['temp_password']) {
        // Code correct → redirection vers la page d'accueil
        header("Location: accueil.php");
        exit;
    } else {
        $error = "Code incorrect, réessaie.";
    }
}
```

Page accueil.php

Pour finir, cette page permet à l'utilisateur d'accéder à son espace.

```
<body>
  <div class="container">
    <?php if ($username): ?>
      <h1>Bienvenue !</h1>
      <div class="welcome-card">
        <h2><?= $username ?></h2>
        <p>Tu es connecté !</p>
      </div>
    <?php else: ?>
      <h1>Accueil</h1>
      <div class="welcome-card">
        <h2>Bienvenue !</h2>
      </div>
    <?php endif; ?>

    <a href="login.php" class="btn-logout">Retour à la connexion</a>
  </div>
</body>
```

Voici le résultat final dans la base de données :

id	username	email	password	created_at	temp_password	temp_updated_at
7	Yanis	person-y@saint-louis29.net	\$2y\$10\$hEZtQvwmC4Um.oVOeELDkeHoQYUHcofiP5w6Ue2NptA...	2025-12-14 16:23:26	530061	2025-12-14 16:42:03



Conclusion

Le TOTP est une méthode simple et efficace pour sécuriser l'accès à vos comptes grâce à des codes temporaires qui changent régulièrement. Il renforce la sécurité des mots de passe et réduit les risques d'accès non autorisé.

Comprendre son fonctionnement permet de l'implémenter correctement et d'assurer une protection fiable des systèmes et des données sensibles.